
Audit de Sécurité et Remédiation RGPD

Cas WellWork

Présenté par Antoine TU - WEB3 2025-26

Fuite de données critiques : 64 salariés exposés

64

PROFILS RH COMPROMIS

134

QUESTIONNAIRES DE SANTÉ

SHA-256

EMPREINTES MOTS DE PASSE

DÉTAILS DE L'INCIDENT ET CONTEXTE

- **Découverte de la fuite** : Identification d'un fichier JSON accessible sur un forum public, contenant l'intégralité de la base de démonstration WellWork.
- **Périmètre des données compromises** : 64 profils RH complets (identités, adresses email), empreintes de mots de passe hachées (SHA-256) et 134 questionnaires médicaux détaillés (évaluation du stress, antécédents, traitements en cours, données biométriques).

IMPACTS ET CONSÉQUENCES MAJEURES

- **Rupture critique du secret médical** : Exposition directe de données de santé hautement sensibles appartenant aux salariés.
- **Risques RH et juridiques** : Danger immédiat de discrimination par les employeurs et exposition à de sévères sanctions réglementaires (RGPD).
- **Menaces cyber accrues** : Vulnérabilité accrue des collaborateurs face à des campagnes de phishing très ciblées (spear-phishing).

Des failles critiques ont permis l'exfiltration massive des données

- **Vecteur principal** : Jeton d'administration statique codé en dur et route d'exportation vers l'assureur non cloisonnée.
- **Exécution de code à distance (RCE)** : Faille critique (Score CVSS 9.9) via l'utilisation de 'new Function' permettant le contrôle total du serveur.
- **Défaut d'autorisation (BOLA)** : Accès libre aux questionnaires de santé des collègues via l'API sans vérification de propriété.



SEVÉRITÉ CRITIQUE

Réponse immédiate et respect strict des obligations de notification RGPD



OH — IMMÉDIAT

Phase 1 · Urgence

Actions d'urgence : Révocation immédiate du jeton administrateur fuité, coupure préventive de la route d'exportation et réinitialisation forcée des mots de passe.



SOUS 24 HEURES

Phase 2 · Information

Communication : Information transparente envoyée sous 24 heures aux 64 salariés impactés, détaillant les données concernées et les mesures prises.



SOUS 72 HEURES

Phase 3 · Conformité

Notification CNIL : Déclaration effectuée sous 72 heures en raison du risque élevé lié à la compromission de données de santé.

Déploiement de correctifs immédiats pour sécuriser la plateforme



SÉCURISATION DE LA PLATEFORME RÉUSSIE

Mise en place immédiate d'actions médiatiques visant la neutralisation des failles critiques et le rétablissement de la conformité réglementaire.

Correctifs Techniques & RGPD

Correction des vulnérabilités

Neutralisation de la faille RCE par un filtrage strict et masquage systématique des empreintes de mots de passe dans l'API.

Gestion du consentement

Suppression du consentement forcé avec un Opt-in désactivé par défaut à l'inscription pour respecter le RGPD.

Isolation Multi-Tenant & Confidentialité

ARCHITECTURE MULTI-TENANT Isolation Stricte des Données

Cloisonnement multi-tenant

Isolation stricte empêchant les équipes RH d'accéder aux données des entreprises concurrentes et aux données médicales.

Une refonte structurelle pour garantir la pérennité et la conformité



PILIER 01

Modernisation Architecture

Migration prévue vers une base **PostgreSQL** sécurisée.

Hébergement certifié **HDS** (Hébergeur de Données de Santé) pour assurer une protection maximale des données sensibles.



PILIER 02

Refonte Authentification

Adoption de **jetons JWT** signés avec expiration courte.

Implémentation d'un hachage robuste des mots de passe via **Argon2id**.



PILIER 03

Intégration DevSecOps

Scans automatisés de secrets intégrés via **GitGuardian**.

Analyses statiques (**SAST**) incluses directement dans le cycle de développement continu.

Bilan de l'audit et structuration de la gouvernance sécurité

Une équipe agile dédiée, incluant le DPO et le RSSI, est mobilisée sur 3 sprints de 2 semaines pour finaliser la remédiation.

- **Bilan immédiat :** Les failles critiques exploitables à distance et les manquements RGPD majeurs ont été identifiés et confinés en urgence.
- **Organisation de la remédiation :** Structuration des opérations autour du DPO et du RSSI pour garantir une réponse coordonnée, technique et réglementaire.
- **Objectif final :** Valider la conformité totale de la plateforme avant l'audit du grand compte.